Zdravo
AI agent governance research

Pre-Execution Authorization of AI-Agent Tool Calls

Single-use, action-bound permits and a hash-chained receipt ledger, with GPU-aware inference routing

Shqiprim Balazoski
shqiprim@zdravo.ai
Measured on a live deployment, 7-day window to 9 Nov 2026

1. Problem and Goal

LLM agents call tools (databases, payments, CRMs) through protocols such as the Model Context Protocol. Most deployments check permissions **once at login** or **after the fact** in logs.

A tool call can be changed, replayed, or made on stale information between approval and execution.

Goal: decide every call *before* it runs, bind the decision to that exact call, and leave evidence a third party can verify without trusting the server.

- Deny by default; fail closed on any error
- One decision permits one action, once
- Every outcome is independently verifiable

2. Threat Model

The agent is untrusted. We test eight attacker moves between approval and execution:

#	Attacker move	Control
1	Alter the tool after approval	Definition integrity
2	Use an ungranted capability	Capability grant
3	Act on expired evidence	Freshness ≤ 30 s
4	Omit required evidence	Freshness required
5	Request prohibited action	Org policy
6	Forge the timestamp	Timestamp validation
7	Replay a valid request	Idempotency binding
8	Use a revoked delegation	Delegation check

3. Contributions

- A fail-closed **authorize** step with six ordered checks before any side effect
- A **permit** bound to a hash of the action, an audience, and a 120 s expiry, consumed atomically
- An append-only, **hash-chained** audit log with signed receipts
- A **live, reproducible** evidence harness, with its failures reported

4. Method: Authorize, Permit, Execute, Receipt

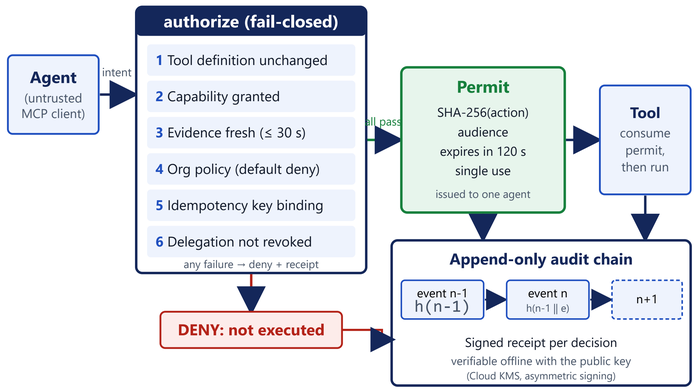


Figure 1. Every call passes six checks. A pass yields a permit bound to a hash of the exact action. The tool consumes the permit atomically before running. Allow and deny both write a receipt.

Permit lifecycle, as exercised end to end



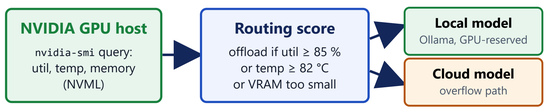
Run 9 Nov 2026 against the live deployment; offline permit and receipt validation both returned valid.

5. Benchmarking Methods

- **Adversarial lab:** 8 attacks plus 2 legitimate controls (before and after), driven through the production UI with a headless browser on 13 Oct 2026. The executor was **simulated**; denials and signed receipts are real, external side effects are not tested.
- **Permit proof:** one scripted allow, tamper, consume, replay sequence on 9 Nov 2026 with a synthetic tool.
- **SLO probe:** read-only queries over metric rows and the audit table for the 7 days before 9 Nov 2026; latency is measured inside the handler (no network, no cold start).
- **Regression:** 4,590 of 4,593 unit and integration tests pass; 3 are skipped.

6. Application of NVIDIA Technology

Policy decisions are deterministic code and database queries; no GPU is in the decision path. NVIDIA hardware is used for the local-inference side of the agent workload.



What is and is not evidenced

Implemented	GPU telemetry via `nvidia-smi`; routing thresholds
Implemented	Compose file reserves one NVIDIA GPU for Ollama
Not measured	Throughput or latency on NVIDIA hardware
Not measured	Effect of GPU load on routing outcomes
Not used	NIM, Triton, TensorRT-LLM (candidates, Sec. 9)

Figure 2. The router reads GPU state and picks local or cloud inference. All results in Section 7 were taken on a deployment with no NVIDIA accelerator in the path.

7a. Results: Adversarial Lab

Step	Outcome	Denial reason (from receipt)
Control	allow	Permitted by policy
1 Change tool	deny	Definition changed; re-approval required
2 No grant	deny	Agent not authorized for capability
3 Stale	deny	Evidence 301 s old; max 30 s
4 No evidence	deny	Required evidence not supplied
5 Prohibited	deny	Export prohibited by org policy
6 Forged time	deny	Missing or future timestamp
7 Replay	deny	Idempotency key already used
8 Revoked	deny	Delegation revoked
Control	allow	Tool restored; signed delegation

8 of 8 attacks blocked; the legitimate action succeeded before and after. Simulated executor, production decision path, 13 Oct 2026.

7b. Results: Live Measurements

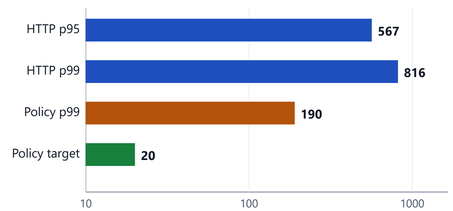
8 / 8
attacks blocked, controls allowed

0 / 963
HTTP 5xx over 7 days

1,106
audit events, 21 orgs, 0 chain breaks*

403 · 409
tamper and replay rejected

Latency against objectives (ms, log scale)



HTTP: n = 963 requests. Policy: n = 2 decisions, includes DB writes.

The policy-latency target was missed: p99 190 ms against 20 ms. With n = 2 this is an upper bound, not a distribution.

*4 breaks are on record as accepted. 18 signatures were created under the integration suite's stub key and are not counted as verified.

8. Limitations and 9. Next Steps

- **Open failures:** 3 data-deletion-worker SLO checks fail (no job has ever run), and 1 of 8 scheduled-work objectives failed (85 of 92 scheduler calls returned 2xx; the target is 99 %).
- **Low load:** peak 9 decisions per minute per organization.
- **Simulated executor** in the attack lab.
- **Next:** benchmark authorize and routing on an NVIDIA GPU host (same harness, p50/p95/p99 under load); evaluate a GPU-served model as an evidence classifier; compare NIM and local serving.

References

- Saltzer and Schroeder, "The Protection of Information in Computer Systems," Proc. IEEE 63(9), 1975.
- Schneier and Kelsey, "Secure Audit Logs to Support Computer Forensics," ACM TISSEC 2(2), 1999.
- Rose et al., NIST SP 800-207, *Zero Trust Architecture*, 2020.
- Josefsson and Liusvaara, RFC 8032: EdDSA, 2017.
- Model Context Protocol specification, modelcontextprotocol.io.
- NVIDIA Management Library (NVML) and `nvidia-smi` documentation; NVIDIA Container Toolkit documentation.